

Sistema de gestión de Seguridad de la Información ANDINA DIGITAL

Documentación Backup y Recuperación

Taller: Diseño de un SGSI - caso Andina Digital S.A.S

Grupo: Grupo 6

Tema: Backup y Recuperación

Marco de referencia - ISO/IEC 27001:2022

El sistema de Gestión de Seguridad de la Información (SGSI) de Andina Digital S.A.S. se estructura conforme a la ISO/IEC 27001:2022. Su cuerpo principal define los requisitos del sistema de gestión de cláusulas A a 10 (contexto de la organización, liderazgo, planificación, apoyo, operación, evaluación del desempeño y mejora), mientras el anexo A reúne 93 controles de referencia organizados en cuatro temas: controles organizacionales (A.5), controles de personas (A.6), controles físicos (A.7) y controles tecnológicos (A.8).

Los tres documentos elaborados por el grupo 6 se enmarcan principalmente en el control A.8.13 - copias de seguridad de la información, complementado por los controles A.5.29 (Seguridad de la información durante la interrupción), A.5.30 (Preparación de las TIC para la continuidad del negocio) y A.8.14 (Redundancia de los servicios de procesamiento de información), así como en las cláusulas 5.2 (Política), 5.3 (Roles, responsabilidades y autoridades), 7.5 (Información documentada) y 9.1 (Seguimiento, medición, análisis y evaluación).

Documento	Cláusula(s) / control(es) ISO/IEC
Política de continuidad del Negocio - Backup y recuperación	Cláusula 5.2 - Anexo A.8.13, A.5.29, A.5.30
Procedimiento de Backup y Recuperación	cláusulas 7.5 y 8.1 - Anexo A.8.13 A.5.37
Template - Backup Schedule	cláusulas 7.5.1(c) y 9.1 - Anexo A.8.13

1. Política de continuidad del Negocio - Backup y Recuperación

Código: POL-BR-01

Versión: 1.0

Fecha de elaboración: 04 - septiembre de 2026

Clasificación: Uso Interno

Elaborado por: Gerencia General (pendiente de firma)

Norma de referencia ISO/IEC 27001:2022

1.1. Objetivo

Establecer las reglas de obligatorio cumplimiento en Andino Digital S.A.S para garantizar la disponibilidad y la capacidad de recuperación de la información y de los sistemas ante fallas técnicas, errores humanos, incidentes de seguridad, desastres o cualquier otro evento que comprometa su integridad o disponibilidad, mediante la generación, verificación y prueba periódica de copias de respaldo.

1.2. Alcance

Esta política aplica a todos los sistemas de información, aplicaciones, base de datos, servidores (locales y en la nube), equipos y repositorios de información de Andino Digital S.A.S. Es obligatorio para empleados, contratistas, proveedores y terceros que administran operen o tengan alguna responsabilidad sobre dichos activos.

1.3. Declaraciones de la política

1. Todo sistema de información clasificado como crítico o de alta disponibilidad para el negocio, según el inventario y la clasificación de activos del SGSI, debe contar con un esquema de copias de respaldo formalmente definido, documentado y aprobado por el Oficial de Seguridad de la Información.
2. La existencia de copias de respaldo no presume: debe existir evidencia verificable de su ejecución, resultado (exitoso o fallido) para cada ciclo.
3. Cada sistema debe tener definidos formalmente un objetivo de Punto de Recuperación (RPO) y un objetivo de tiempo de recuperación (RTO).
4. Las copias de respaldo deben almacenarse en un medio o ubicación distinta al sistema de origen protegidas mediante cifrado y controles de acceso.
5. Todo proceso de backup debe ser verificado por una persona distinta de quien lo ejecuta o programa, con constancia de esa verificación.
6. La capacidad real de restauración debe probarse periódicamente mediante pruebas formalmente programadas y documentadas. Confirmar que el backup se ejecutó no es suficiente si no se confirma que la restauración es posible dentro del RTO definido.
7. Todo cambio en el esquema de backup de un sistema (frecuencia, retención, tipo de copia o ubicación de almacenamiento) requiere análisis y aprobación previa del Oficial de Seguridad de la Información, y debe gestionarse conforme a la política de gestión de cambios de la compañía.
8. Los periodos de retención de un las copias de respaldo se definen considerando los requisitos legales, contractuales y del negocio aplicables a cada sistema, y las copias vencidas deben eliminarse de forma segura.
9. Toda falla en la ejecución de un backup programado, o en una prueba de restauración, constituye un evento que debe reportarse y gestionarse conforme al procedimiento de gestión de incidentes de seguridad.
10. El acceso a las herramientas, consolas y repositorios de backup se otorga al personal autorizado, conforme a la política de control de acceso de la compañía, y queda sujeto a revisión periódica.

14. Roles y responsabilidades

Rol	Responsabilidad
Gerencia general	Aprobaba la Política de continuidad y el esquema general de backup; asigna los recursos necesarios.
Oficial de Seguridad de la Información	Aprobaba el esquema de backup de sistemas críticos, hace seguimiento y auditoría periódica, y gestiona los incidentes derivados de fallas.
Gerencia de Tecnología	Garantiza los recursos técnicos, asigna al administrador responsable de cada sistema y aprueba cambios.
Propietario de la información / Área de negocio	Clasifica la criticidad del sistema, define el RPO y el RTO requeridos, y solicita cambios al esquema cuando se requiera.
Administrador de Infraestructura (ejecutor)	Configura, programa y ejecuta el backup conforme al esquema aprobado, documenta la ejecución.
Administrador de Infraestructura (Verificador)	Persona distinta al ejecutor. Verifica que cada backup se haya ejecutado correctamente y registra el resultado.
Responsable de pruebas de restauración.	Ejecuta las pruebas periódicas de restauración en ambiente controlado y documenta el resultado frente al RTO definido.
Proveedores externos (cuando administran sistemas)	Ejecuta el backup según el contrato y esta política, permiten auditoría por parte de Andina Digital SAS

15. Cumplimiento y revisión

El cumplimiento de esta política será verificado por el Oficial de Seguridad de la Información como parte del seguimiento periódico del SGSI. La política será revisada al menos una vez al año, o antes si se presentan cambios significativos en la infraestructura, el negocio o los requisitos legales o contractuales aplicables, y toda modificación requiere la aprobación de la alta dirección.

1.6 trazabilidad con ISO/IEC 27001:2022

Elemento de la Política	Clausula / Control ISO/IEC 27001:2022
Aprobación de la Política por alta dirección	Clausula 5.2 - Política
Definición de roles y responsables	Clausula 5.3 - Roles, responsabilidades y Autoridades organizacionales
Esquema de backup - RPO y RTO por sistema	Anexo A.5.29 - Seguridad de la Información durante la disrupción
Continuidad operativa ante disrupciones	Anexo A.8.13 - copias de seguridad de la información
Preparación tecnológica para la continuidad del negocio	Anexo A.5.30 - Preparación de los TIC para la continuidad del negocio
Redundancia del almacenamiento de las copias	Anexo A.8.14 - Redundancia de los Servicios de Procesamiento de la Información
Control de Acceso a herramientas y Repositorios de backup	Anexo A.5.15 - Control de acceso
Aprobación de cambios al esquema del backup	Anexo A.8.32 - Gestión de cambios
Reporte de fallos de backup como Incidente de seguridad	Anexo A.5.21-A.5.28 - Gestión de incidentes de seguridad de la Información

2. Procedimiento de backup y recuperacion

Código: PRD-BR-01

Version: 1.0

Fecha de elaboración: 03 de sept 2026

Aprobado por: Gerencia de tecnología / Oficial de seguridad

Documento base:

Clasificación: Uso interno

2.1 Objetivo

Describir las actividades, los responsables, los tiempos y las evidencias necesarias para planear, ejecutar, verificar y probar las copias de respaldo de sistemas de Andina Digital SAS, en el cumplimiento de la política de continuidad del negocio - Backup y recuperación.

2.2 Alcance

Aplica a todos los sistemas incluidos en el inventario de activos de información que hayan sido clasificados como objeto de backup, ya sean administrados por la Gerencia de Tecnología o por proveedores externos autorizados.

2.3 Roles y responsabilidades en el procedimiento

Se aplican los roles definidos en la política. El procedimiento exige, en particular, que quien ejecute el backup y quien lo verifica sean personas distintas, con el fin de evitar que el proceso dependa del criterio de una sola persona, tal como se identificó como debilidad durante la revisión interna.

2.4 Actividades

Etapas 1 - Identificación y clasificación de sistemas

1. La Gerencia de tecnología, con apoyo de los propietarios de la información, identifica los sistemas, bases de datos y repositorios que requieren backup, con base en el ~~in~~ inventario de activos de información de S6SI.

2. Para cada sistema se define su criticidad, de RPO y el RTO requeridos, el tipo de información que contiene y los requisitos contractuales aplicables.

3. El oficial de seguridad de la información valida y aprueba la clasificación resultante.

Etapa 2 - Definición del esquema de backup

4. Para cada sistema se define el tipo de copia (completa, incremental o diferencia), la frecuencia, la ventana horaria de ejecución, la ubicación o medio de almacenamiento, el cifrado aplicado y el periodo de retención.
5. El esquema de finido se documenta en el template backup Schedule y se somete a aprobación de la gerencia de tecnología y del oficial de seguridad de la información.
6. Cualquier modificación posterior al esquema aprobado se gestiona a través del procedimiento de gestión de cambios de la compañía.

Etapa 3 - Ejecución

7. El administrador de infraestructura (ejecutor) configura la herramienta de backup conforme el esquema aprobado, priorizando su automatización.
8. El backup se ejecuta según lo programado. La herramienta debe generar un registro automático de la ejecución, con fecha, hora, tamaño y resultado.

Etapa 4 - Verificación

9. Con la verificación de finida para cada sistema, el administrador verificador revisa el resultado de cada backup ejecutado y registra la verificación en el template backup schedule.
10. Si el backup falla o no se ejecuta, el verificador lo reporta de inmediato como incidente de seguridad de la información conforme el procedimiento de gestión de incidentes, e informa a la gerencia de tecnología para su corrección dentro del plazo definido según la criticidad del sistema.

Etapa 5 - Prueba de restauración

11. Con periodicidad mínima trimestral para sistemas críticos y semestral para los demás, el responsable de pruebas ejecuta una restauración de prueba en un ambiente controlado, distinto del ambiente de producción.
12. Se documenta el resultado de la prueba (exitosa o fallida), el tiempo real que toma la restauración frente a RTO definido, y cualquier hallazgo relevante, en el registro de pruebas del template.

13. Si la prueba resulta fallida, o el tiempo de restauración supera el RTO definido, se abre un plan de acción correctivo con responsable y Fecha de cierre, y se informa al oficial de seguridad de la información.

Etapa 6 - Almacenamiento, retención y disposición

14. Las copias se almacenan cifradas, en una ubicación distinta al sistema de origen, con acceso restringido al personal autorizado.

15. Al vencer el período de retención definido para cada sistema, las copias correspondientes se eliminan de forma segura y dicha eliminación queda registrada.

Etapa 7 - Auditoría y mejora continua:

16. El oficial de seguridad de la información realiza revisiones periódicas, con una frecuencia mínima semestral, sobre el cumplimiento del esquema del Backup en los sistemas críticos, y reporta los resultados a la gerencia general.

2.5 Evidencias generadas por el procedimiento

- Template backup schedule diligenciado, con la programación, ejecución y verificación de cada ciclo de backup.
- Registro de pruebas de restauración, con su resultado y el tiempo de restauración obtenido.
- Reportes de incidentes asociados a fallas de backup de restauración.
- Actas o registros de aprobación de cambios al esquema de backup.

2.6 trazabilidad con ISO/IEC 27001:2022

Elemento del Procedimiento

Clausula/Control ISO/IEC 27001:2022

Documento del Procedimiento como información documentada de SGSI

Clausula 7.5 - Información documentada

Planificación y control de la ejecución del backup

Clausula 8.1 - Planificación y control operacional

Ejecución, Verificación y Pruebas de restauración

Anexo A.8.13 - Copias de seguridad de la información

Procedimiento de operación documentada

Anexo A.5.37 - Gestión de incidentes de seguridad de la información

Acción Correctiva ante fallas de backup o de restauración

Clausula 10.2 - No conformidad y acción correctiva

Reporte de fallas como incidente de seguridad

Anexo A.5.24 - A.5.28 - Gestión de incidentes de seguridad de la información

~~Acción~~ Revisión Periódica del cumplimiento del esquema

Clausula 9.1 - Seguimiento, medición, análisis y evaluación

3. Template - Backup schedule

Código	FOR-BR-01
Version	1.0
Fecha de elaboración	03 de septiembre de 2016
Clasificación	Uso Interno
Documentos Base	POL-BR-01 y PRO-BR-01

Formato ~~anexo~~ utilizado para registrar la Programación, ejecución, verificación y Pruebas de restauración de las copias de Respaldo de cada Sistema, como evidencia del cumplimiento de la Política y Procedimiento de backup y recuperación. Debe diligenciarse un registro (Parte A) por cada sistema incluido el alcance, y consignarse cada ciclo de ejecución y Prueba de restauración en las tablas de Seguimiento (Partes B y C)

Parte A - Datos generales del sistema

Sistema / Activo	ERP Corporativo
Propietario de la información	Gerencia administrativa
Críticidad	Alta
RPO	24 horas
RTO	4 horas
tipo de copia	Completa (semanal) + incremental (diaria)
Frecuencia	Diaria, 11:00 P.M.
Ubicación de almacenamiento	Repositorio de C. Trato en la nube en distinto al servidor de origen
Periodo de Retención	90 días
administrador executor	(Nombre administrador responsable de ejecutar el backup)
Administrador Verificador	(Nombre del administrador responsable de verificar el backup)
Aprobado Por	Oficial de Seguridad de la Información / Gerencia Tecnológica
Fecha Aprobación	

Parte B - registro de ejecución y verificación

Fecha Programada	Fecha Ejecución	tiro de conia	resultado	tamaño	verificado por	Fecha Verificación	observaciones
			☐ Exitoso ☐ fallido				
			☐ Exitoso ☐ fallido				
			☐ Exitoso ☐ fallido				
			☐ Exitoso ☐ fallido				

Parte C - registro de Pruebas de restauración

Fecha de Prueba	sistema/ dato restaurado	responsable de la prueba	RTO objetivo	tiempo real de restauración	Resultado	Observación/ Planación
					☐ Exitoso ☐ fallido	
					☐ Exitoso ☐ fallido	
					☐ Exitoso ☐ fallido	

Scribe

Este formato debe conservarse como evidencia del SGSI y estar disponible para auditoría interna o de clientes, conforme a los requisitos contractuales de confidencialidad y disponibilidad establecidos con estos.

Trazabilidad con ISO/IEC 27001:2022

Elemento del template	Cláusula/Control ISO/IEC 27001:2022
Registro como evidencia objetiva de conformidad de SGSI	Cláusula 7.5.1(c) - Información documentada requerida por SGSI
Seguimiento del desempeño del proceso de backup	Cláusula 9.1 - Seguimiento, medición, análisis y evaluación
Evidencia de Control de copias de Seguridad	Anexo A.8.13 - Copias de seguridad de la información